Case - Study :-

1) Bright Mart is a medium sized online shopping company, customers use its web and mobile application to purchase products.

The company stores:

1) 1st customer names
2) email addresses
3) Phone numbers
4) Delivery addresses
5) Passwords
6) Order information
7) Payment - related information

Bright Mart has around 100 employees

→ The company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

However, the company has the following security weaknesses:

- Some employees use simple passwords such as Bright Mart 123.

- Many employees use ~~same~~ same password for multiple systems.
- Software updates are delayed sometimes.
- The company does not regularly conduct employe cybersecurity training.
- There is no multi-factor authentication for some important accounts.
- Employees can access sensitive information that they do not necessarily need for their jobs.
- Backups are performed only once a month.

The Incident:-

On monday morning, an employee named Rahul receives an email.

Subject: Urgent - Your Account will be suspended

The email appears to comes from the company's IT department.

→ It says:

"Your company account will be suspended today. Click the link below and verify your password immediately."

→ Rahul clicks the link

→ The page almost looks identical to the company's login page.

→ He enters his username and password.
→ Rahul does not realize that the website is controlled by an attacker.
→ The attacker now has Rahul's login credentials.

- Stage -1 → Unauthorized Access:

The attacker uses Rahul's credentials to access Bright Mart's internal system.

Because Rahul uses the same password for another system, the attacker is also able to access that system.

The attacker discovers that Rahul has access to customer information.

The attacker downloads a large amount of customer data.

What cybersecurity problem has occured?

- Stage -2 → Malware attack:

The attacker sends another email to Rahul containing a malicious attachment. Rahul opens the attachment. Malware is installed on his computer.
The malware begins communicating with the attacker's system.

The attacker now attempts to move from Rahul's computer to other systems within Bright Mart's network.

Which vulnerability allowed the attacker to move further into the organization?

- Stage-3 → Ransomware:

Two days later, employee arrive at work and discovers that they cannot access important files. A message appears on their computers:

"Your files have been encrypted. Pay the ransom to recover them"

The company's customer database and several important business files are encrypted. Unfortunately, the company's most recents backup is almost a month old.
The website stops working.
Customers cannot place orders.
The customer-support team cannot access records.

- Stage-4 → Business Impact:

Bright Mart now faces several Problems.

- Finance: loses sales because website is unavailable
- Data: Customer Information may have been stolen.
- Operational: Employees can't access important

systems.

- Reputation: Customers lose confidence in company
- legal: They may face regulatory or legal consequences depending on what information was exposed & which laws apply.

Group 1 - Identify Threats

Q. What threats are present in this case?

1) Phishing
2) Malware or ransomware
3) Credential theft & Data theft
4) Unauthorized access

Group 2 - Identify the Vulnerabilities

Q. What weaknesses in Bright Mart's security allowed the attack to succeed?

Vulnerability	How it helped
1) Weak passwords	1) Easier to compromise accounts
2) Password reuse	2) Access to multiple systems
3) No MFA	3) Stolen passwords are enough to log in

DATE
PAGE

✳ Group 3 - Apply the CIA Triad

Q. Was confidential information exposed?

Yes, customer information was accessed / downloaded by the attacker.

Q. Was information changed or damaged?

Potentially yes, the attacker could modify or encrypt files.

Q. Were systems available to legitimate users?

No, the website & internal systems were unavailable.

✳ Group 4 - Security Solutions

Q. Who is responsible for cybersecurity?

Not only the IT department. Every employee who uses the organization systems has a role in cybersecurity.

Q. Was phishing the only problem?

No, Phishing was the initial attack, but weaknesses like password reuse, no MFA, poor backups, etc allowed the attacking to become much more damaging.

DATE
PAGE

2. What was the biggest vulnerability?

lack of employee awarness was the biggest vulnerability because the attack would not have happened if Rahul did not click on the link.

5/18/26